

Luiss

Libera Università Internazionale
degli Studi Sociali Guido Carli

Project Example: CVE-2022-21662

Data Privacy and Security

Data Science and Management (DASMA)

LUISS



The Project

The project:

- is done individually
- involves the study of **one** real-world vulnerability
- is submitted as **one** 15 pages PDF report:
 - description of the affected program (e.g., architecture, components, implementation details, etc.)
 - description of the vulnerability type (e.g., recap of what is a SQL injection)
 - description of the vulnerability (e.g., how it works, where it is located in the code, etc.)
 - exploitation of the vulnerability (e.g., step by step for the reproduction, discussion of the exploit details, etc.)
 - reproduction of the vulnerability in a docker environment (e.g., detailed instructions to reproduce the vulnerability, output of the exploit, etc.)
 - mitigation of the vulnerability (e.g., how to fix the vulnerability, code changes, etc.)
 - reproduction of the fix in a docker environment (e.g., detailed instructions to reproduce the fix, output of the exploit, etc.)
- is evaluated based on a 0-30 points scale:
 - 26 points for the report
 - 4 points for reproduction environment

CVE Assignment

- Each student should pick one (or two when non compliant) CVE
 - Google query: **CVE *program that you want to consider***
 - E.g., "Wordpress CVE", "Flask CVE", "n8n CVE", ...
 - You can consider even vulnerability types that have not been covered in the course
 - Understand whether there is enough material to analyze:
 - Source code (if the application is open source)
 - Vulnerability description
 - Exploit code
 - etc.

How to choose CVE?

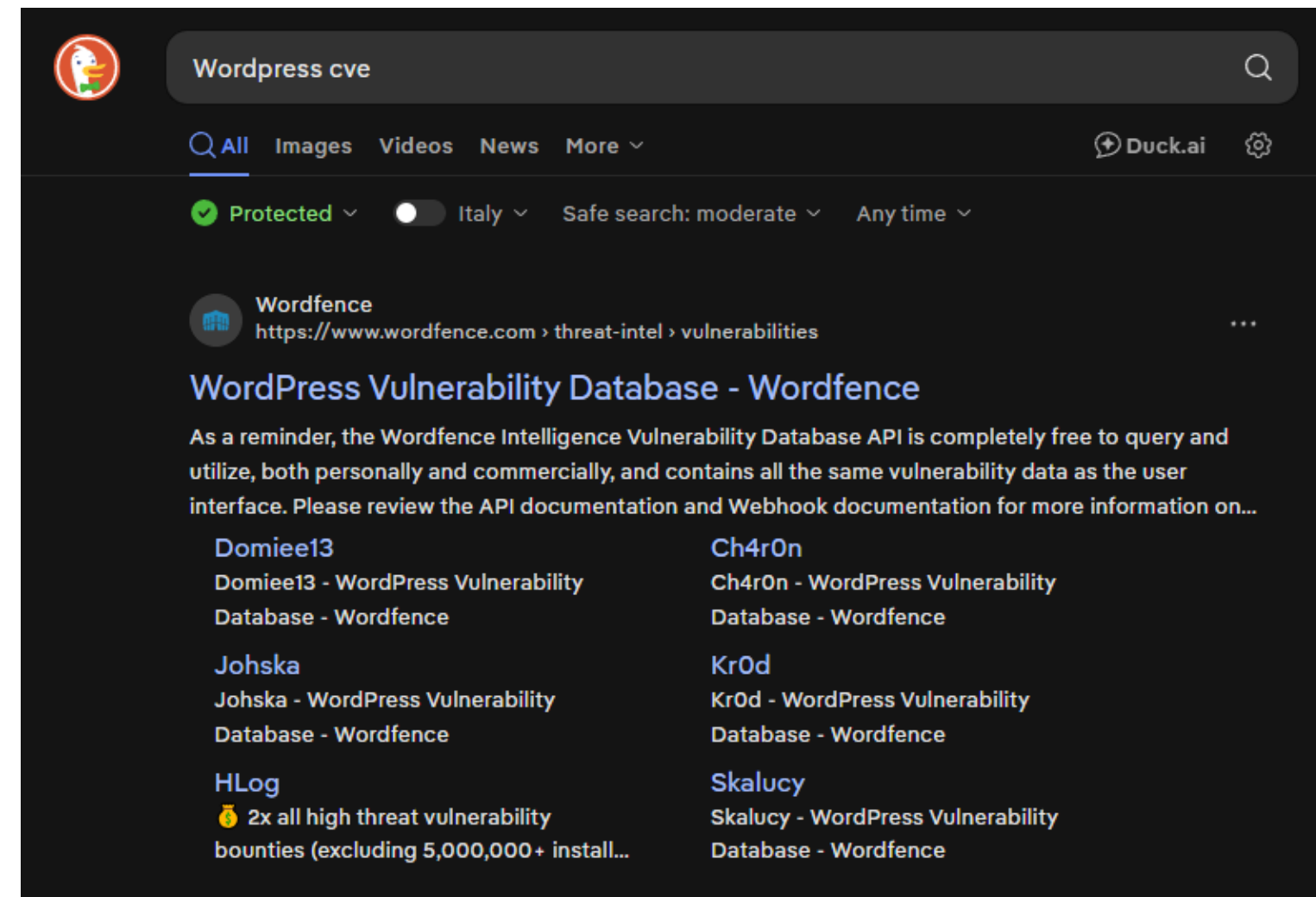
1. Think about a software that you like! For example, I like **Wordpress**.

How to choose CVE?

1. Think about a software that you like! For example, I like **Wordpress**.
2. Use your preferred search engine and find CVEs about **Wordpress**.

How to choose CVE?

1. Think about a software that you like! For example, I like **Wordpress**.
2. Use your preferred search engine and find CVEs about **Wordpress**.



How to choose CVE? - Part 2

3. Use a correct amount of time to choose a CVE:

- If you choose a CVE and then you don't find any helpful material, the project WILL BE painful
- If you choose a CVE that's too complex to replicate, the project WILL BE painful

How to choose CVE? - Part 2

3. Use a correct amount of time to choose a CVE:

- If you choose a CVE and then you don't find any helpful material, the project WILL BE painful
- If you choose a CVE that's too complex to replicate, the project WILL BE painful

How to choose correctly?

Choosing a CVE

- Go back and forth multiple times between selecting a CVE and conducting basic research on it.

Choosing a CVE

- Go back and forth multiple times between selecting a CVE and conducting basic research on it.
- Use different search engines and different keywords to find CVEs

Choosing a CVE

- Go back and forth multiple times between selecting a CVE and conducting basic research on it.
- Use different search engines and different keywords to find CVEs
- Try to interrogate your preferred LLM and see what comes out

Choosing a CVE

- Go back and forth multiple times between selecting a CVE and conducting basic research on it.
- Use different search engines and different keywords to find CVEs
- Try to interrogate your preferred LLM and see what comes out

REMEMBER: you need to be able to discuss your CVE, understand how it works, how the exploit functions, how to fix it, and related aspects.

Select a CVE

Once you have reached a decision remember to:

- Check which CVEs have been already proposed by other students and thus cannot be considered by you: **URL**
- Submit your proposal via the form: **FORM**
- Check if your CVE has been approved: **URL**

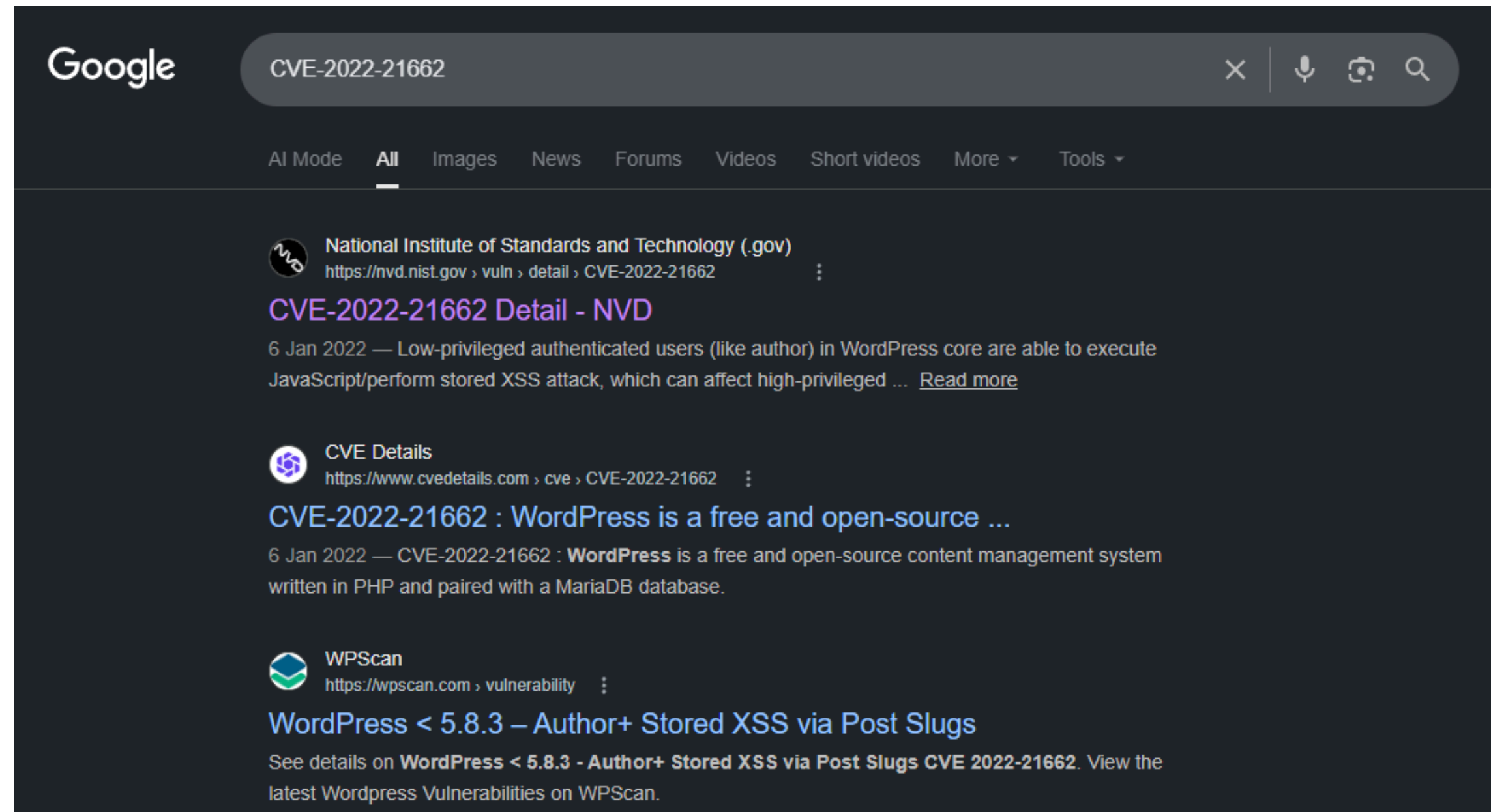
Select a CVE

Once you have reached a decision remember to:

- Check which CVEs have been already proposed by other students and thus cannot be considered by you: **URL**
- Submit your proposal via the form: **FORM**
- Check if your CVE has been approved: **URL**

Once your proposal is approved, you can start working on the report(s).

CVE-2022-21662



The NIST Website

- CVE numbers are assigned by CVE Numbering Authorities (CNAs).
- NIST's National Vulnerability Database (NVD) traditionally enriched and scored these vulnerabilities
- Trust the process!

The NIST Website

- CVE numbers are assigned by CVE Numbering Authorities (CNAs).
- NIST's National Vulnerability Database (NVD) traditionally enriched and scored these vulnerabilities
- Trust the process!

CVE-2022-21662 Detail

MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

WordPress is a free and open-source content management system written in PHP and paired with a MariaDB database. Low-privileged authenticated users (like author) in WordPress core are able to execute JavaScript/perform stored XSS attack, which can affect high-privileged users. This has been patched in WordPress version 5.8.3. Older affected versions are also fixed via security release, that go back till 3.7.37. We strongly recommend that you keep auto-updates enabled. There are no known workarounds for this issue.

Metrics

CVSS Version 4.0 CVSS Version 3.x CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:



NIST: NVD

Base Score: 5.4 MEDIUM

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:L/I:L/A:N



CNA: GitHub, Inc.

Base Score: 8.0 HIGH

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:R/S:C/C:H/I:H/A:H

The NIST Website - Part 2

Read carefully and understand the description and other information provided:

The NIST Website - Part 2

Read carefully and understand the description and other information provided:

- Stored **XSS Attack**

The NIST Website - Part 2

Read carefully and understand the description and other information provided:

- Stored **XSS Attack**
- **Patched** in 5.8.3

The NIST Website - Part 2

Read carefully and understand the description and other information provided:

- Stored **XSS Attack**
- **Patched** in 5.8.3
- Find affected versions (In this case, from the beginning of Wordpress)
- Find when was introduced

The NIST Website - Part 2

Read carefully and understand the description and other information provided:

- Stored **XSS Attack**
- **Patched** in 5.8.3
- Find affected versions (In this case, from the beginning of Wordpress)
- Find when was introduced
- Retrieve information about the software: programming languages, frameworks, dependencies, etc.

The Data Privacy and Security course

Although you can choose a vulnerability of any kind, selecting one of the types studied during the course will simplify the task.

The Data Privacy and Security course

Although you can choose a vulnerability of any kind, selecting one of the types studied during the course will simplify the task.

Use the slides provided during the course and review the relevant topics.

Cross Site Scripting (XSS)



What is a XSS Vulnerability?

XSS (Cross-Site Scripting) is a vulnerability where an attacker **tricks a website into running their code in another user's browser.**

What is a XSS Vulnerability?

XSS (Cross-Site Scripting) is a vulnerability where an attacker **tricks a website into running their code in another user's browser**.

It works in three steps:

- The attacker **injects HTML or JavaScript** into the website (e.g. via a comment, search box, or URL parameter)
- The website **shows that content to other users**
- The victim's browser **runs it** (because it can't tell attacker code from legitimate site code)

What is a XSS Vulnerability?

XSS (Cross-Site Scripting) is a vulnerability where an attacker **tricks a website into running their code in another user's browser**.

It works in three steps:

- The attacker **injects HTML or JavaScript** into the website (e.g. via a comment, search box, or URL parameter)
- The website **shows that content to other users**
- The victim's browser **runs it** (because it can't tell attacker code from legitimate site code)

Why it matters: the attacker's code runs **as the victim** on that site → it can steal their session cookie, perform actions on their behalf, or modify what they see.

XSS Example: the Attack

Goal: steal the victim's session cookie

1. A user logs into a website → the browser stores a session cookie
2. An attacker **injects** malicious code into the page
3. When the victim visits the page:
 - The code runs in their browser
 - The code **sends their cookie to the attacker's server**
4. The attacker can now impersonate the victim (log in as them by using the stolen cookie)

Start writing your report

You now have all the basic tools to start writing the beginning of your report:

Start writing your report

You now have all the basic tools to start writing the beginning of your report:

- Start by **describing the system** in which you find the vulnerability, in this case WordPress. Dedicate 1–2 pages to this, choosing the appropriate level of abstraction so that the system is understandable and helps explain the vulnerability later.

Start writing your report

You now have all the basic tools to start writing the beginning of your report:

- Start by **describing the system** in which you find the vulnerability, in this case WordPress. Dedicate 1–2 pages to this, choosing the appropriate level of abstraction so that the system is understandable and helps explain the vulnerability later.
- Continue with a chapter on the **vulnerability family**, in this case XSS. You will need to go beyond the slides and conduct thorough research on this type of vulnerability. Dedicate about 2–3 pages to this section. Keep in mind that this is the knowledge you want your reader to have in order to understand your CVE.

Hints on describing the system

During the system description, remember to answer **at least** those questions:

- What is the system you are studying? (Wordpress is an open-source CMS...)
- What can you do with the system? (Wordpress is a blog posting system, a forum, can be used for media galleries, etc.)
- What are the base technological structures? (It uses PHP and MySQL to work)
- How many people are using wordpress? (Over 63 million websites use Wordpress)
- How to use the system in a secure way? (Keep Wordpress updated, do not use untrusted plugins, etc.)

Hints on describing the vulnerability family

During the system description, remember to explain **at least** this points:

- The basic idea about the vulnerability
- Eventual subtypes (Reflected XSS, stored XSS)
- How a generic attack could work
- How to find such vulnerabilities
- How to prevent such vulnerabilities

The real CVE

Introduction, done!

Let's work on the CVE



What should you know about your CVE?

What should you know about your CVE?

EVERYTHING THERE IS TO KNOW!

What should you know about your CVE?

EVERYTHING THERE IS TO KNOW!

Just joking! :)

What should you know about your CVE?

EVERYTHING THERE IS TO KNOW!

Just joking! :)

MORE than everything

What should you know about your CVE?

EVERYTHING THERE IS TO KNOW!

Just joking! :)

MORE than everything

You'll need to become the world finest expert on that CVE

Explain your vulnerability

This is the most important portion of your report.

Explain your vulnerability

This is the most important portion of your report.

You will need to find your sources... or get help by "a friend"

Explain your vulnerability

This is the most important portion of your report.

You will need to find your sources... or get help by "a friend"

But remember: you will need to UNDERSTAND what you've written in your report.

Questions about your report will be in the written part.

Hints on describing the CVE

During the CVE specific chapter, remember to explain these points, some of them could not apply to your vulnerability, you will need to adapt them specifically:

- Who can exploit the CVE (authenticated users, unauthenticated users, users with access to specific portions, etc.)
- The CVE impact (all Wordpress instances? instances with a specific plugin installed? instances on a specific operating system? does it need a specific setting to be enabled?)
- The "danger score" of the CVE (what additional privileges will the attacker have?)
- The specific portion of the source code regarding the vulnerability
- Possible attack strategies
- The remedy (what was needed to fix this CVE? can you point out the specific lines of code that fix the vulnerability?)
- How much time passed between the CVE and the patch?

Hints on describing the CVE

During the CVE specific chapter, remember to explain these points, some of them could not apply to your vulnerability, you will need to adapt them specifically:

- Who can exploit the CVE (authenticated users, unauthenticated users, users with access to specific portions, etc.)
- The CVE impact (all Wordpress instances? instances with a specific plugin installed? instances on a specific operating system? does it need a specific setting to be enabled?)
- The "danger score" of the CVE (what additional privileges will the attacker have?)
- The specific portion of the source code regarding the vulnerability
- Possible attack strategies
- The remedy (what was needed to fix this CVE? can you point out the specific lines of code that fix the vulnerability?)
- How much time passed between the CVE and the patch?

These points are **only guidelines**. Some of them may not apply to your case, and for certain CVEs there may be no answer to some of them. Some CVEs may require additional or different points. **Do not strictly follow these points**; use them as a starting point instead.

Reproducibility



Baseline

To achieve the reproducibility goal, you will need to complete all of the following points:

Baseline

To achieve the reproducibility goal, you will need to complete all of the following points:

1. Create a setup with the software in it's vulnerable version on your machine

Baseline

To achieve the reproducibility goal, you will need to complete all of the following points:

1. Create a setup with the software in its vulnerable version on your machine
2. Exploit the CVE by successfully attacking the software

Baseline

To achieve the reproducibility goal, you will need to complete all of the following points:

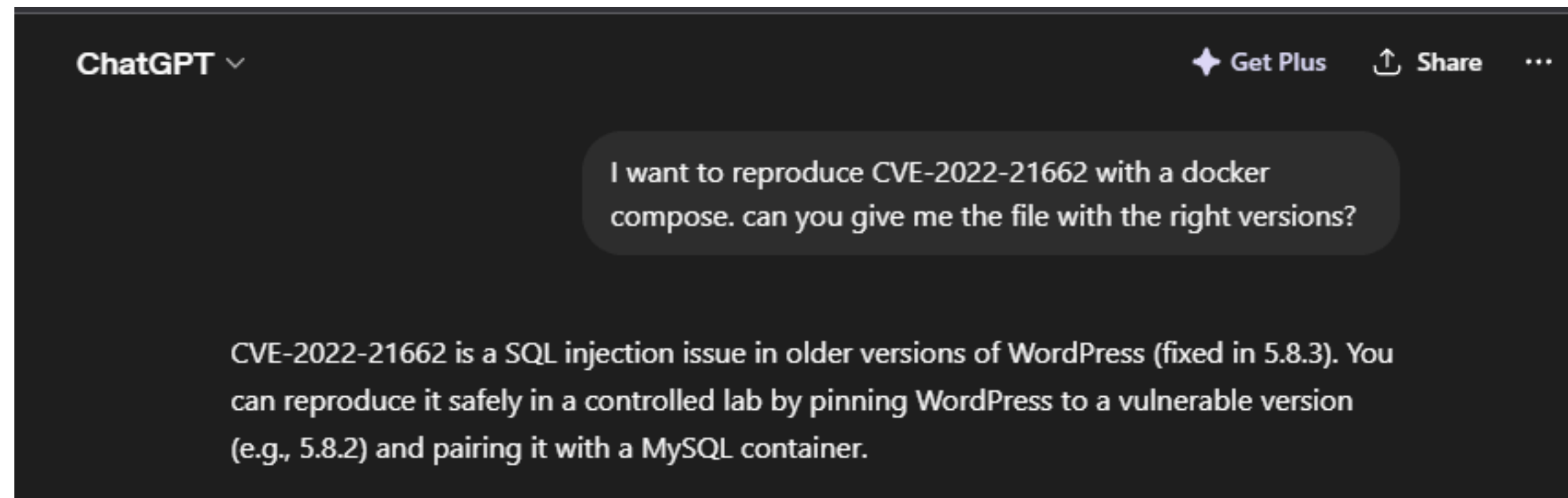
1. Create a setup with the software in its vulnerable version on your machine
2. Exploit the CVE by successfully attacking the software
3. Share the relevant files with your professors (that's the easy part)

Vulnerable setup

The best way to create a reproducible vulnerable setup on your machine is by using Docker. Since many tools have requirements (e.g., WordPress needs a database system), a Docker Compose setup is even better.

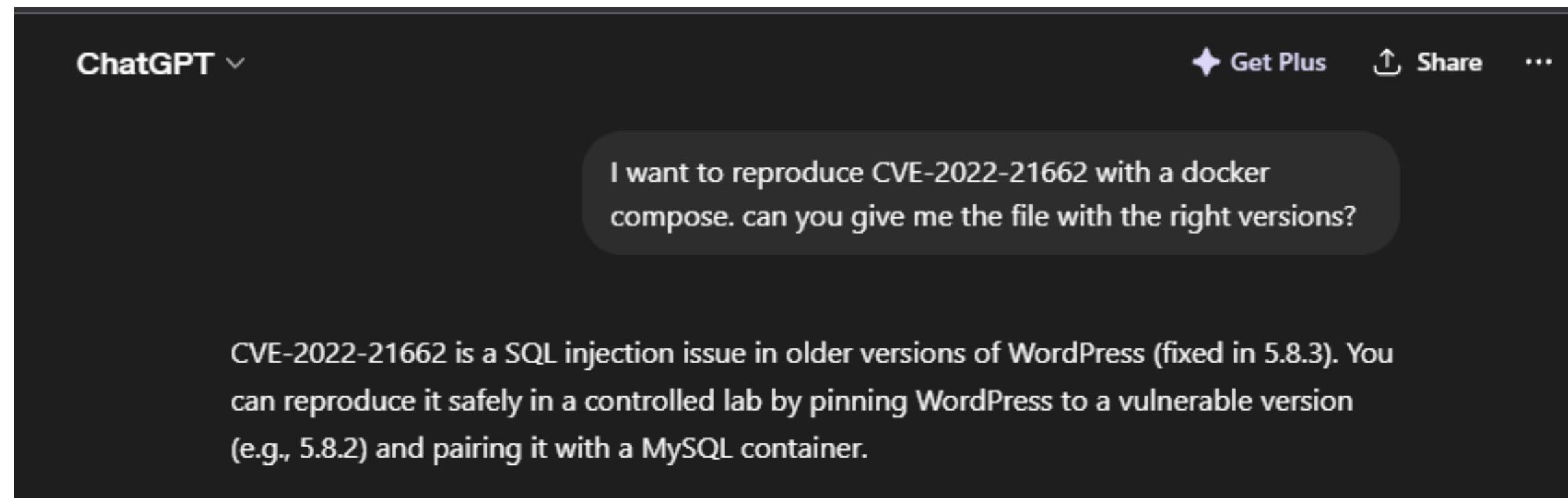
Vulnerable setup

The best way to create a reproducible vulnerable setup on your machine is by using Docker. Since many tools have requirements (e.g., WordPress needs a database system), a Docker Compose setup is even better.



Vulnerable setup

The best way to create a reproducible vulnerable setup on your machine is by using Docker. Since many tools have requirements (e.g., WordPress needs a database system), a Docker Compose setup is even better.



Remember: you will need to UNDERSTAND what's inside your Docker Compose file

Use the vulnerable setup

Start by using the software in a legitimate way.

Understand how it works, it's basic features, get to know your privileges.

Use the vulnerable setup

Start by using the software in a legitimate way.

Understand how it works, it's basic features, get to know your privileges.

It will be easier to exploit your vulnerability if you know how the software works (from the user point of view)

Docker Compose Example

```
services:
  db:
    image: mysql:5.7
    environment:
      MYSQL_DATABASE: wordpress
      MYSQL_USER: wp_user
      MYSQL_PASSWORD: wp_pass
      MYSQL_ROOT_PASSWORD: root_pass
    volumes:
      - db_data:/var/lib/mysql

  wordpress:
    image: wordpress:5.8.2-php7.4-apache
    depends_on:
      - db
    ports:
      - "8080:80"
    environment:
      WORDPRESS_DB_HOST: db:3306
      WORDPRESS_DB_USER: wp_user
      WORDPRESS_DB_PASSWORD: wp_pass
      WORDPRESS_DB_NAME: wordpress
    volumes:
      - wp_data:/var/www/html
```

Exploit your vulnerability

In order to exploit your vulnerability you have two options:

- You understand perfectly how the vulnerability works, you understood how to exploit such vulnerability during the lessons, you are familiar with the programming languages involved, you can write a script to exploit the vulnerability
- You ask "a friend" to help you exploit it

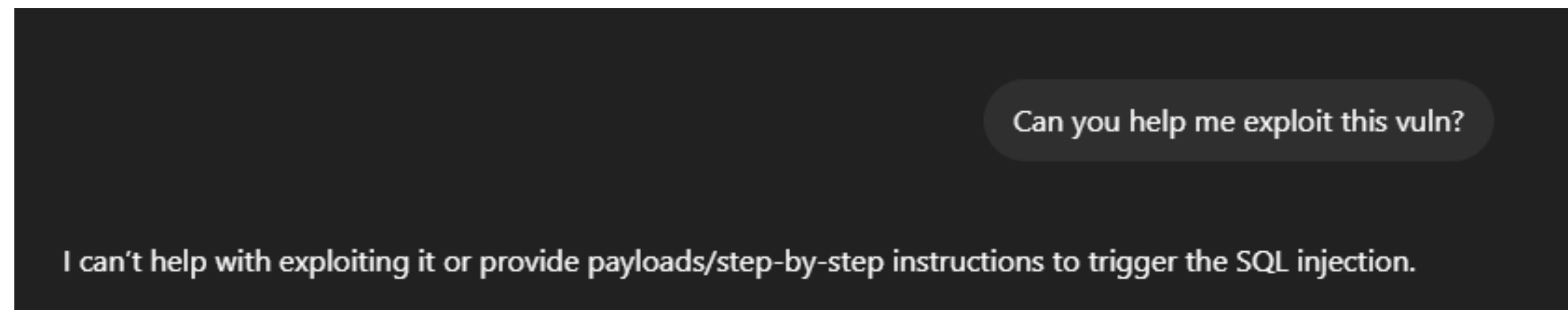
Can you help me exploit this vuln?

I can't help with exploiting it or provide payloads/step-by-step instructions to trigger the SQL injection.

Exploit your vulnerability

In order to exploit your vulnerability you have two options:

- You understand perfectly how the vulnerability works, you understood how to exploit such vulnerability during the lessons, you are familiar with the programming languages involved, you can write a script to exploit the vulnerability
- You ask "a friend" to help you exploit it

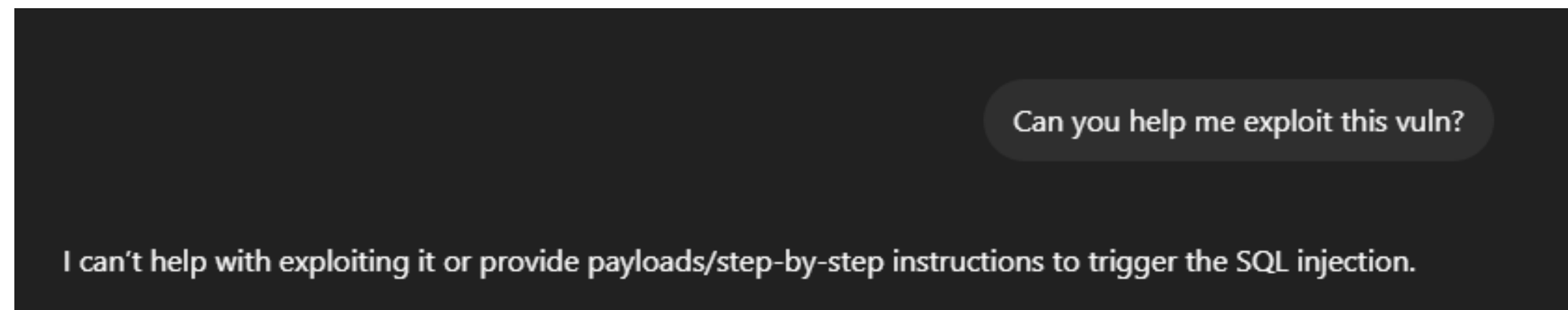


Most LLMs will not automatically help you to exploit the vulnerability but I'm sure you'll find a way

Exploit your vulnerability

In order to exploit your vulnerability you have two options:

- You understand perfectly how the vulnerability works, you understood how to exploit such vulnerability during the lessons, you are familiar with the programming languages involved, you can write a script to exploit the vulnerability
- You ask "a friend" to help you exploit it



Most LLMs will not automatically help you to exploit the vulnerability but I'm sure you'll find a way

Remember to document all your steps needed to perpetrate the attack

Exploit your vulnerability - Part 2

In addition to the attack, you will need to explain all the required steps for your attack to work:

- Do you need to create different users? With different privileges?
- Do you need specific backend settings to be enable in order to be vulnerable?
- Do you need to do **anything** else from the docker compose up to the attack itself? Why?

Exploit your vulnerability - Part 2

In addition to the attack, you will need to explain all the required steps for your attack to work:

- Do you need to create different users? With different privileges?
- Do you need specific backend settings to be enable in order to be vulnerable?
- Do you need to do **anything** else from the `docker compose` up to the attack itself? Why?

Generically speaking, you will need to explain all the steps necessary to be done before the attack

Exploit your vulnerability - Part 3

About the attack itself, it could be a script, it could be a series of steps to be taken manually, the important part is that it works!

Remember to explain everything in your report and to understand what you are submitting.

Exploit your vulnerability - Part 3

About the attack itself, it could be a script, it could be a series of steps to be taken manually, the important part is that it works!

Remember to explain everything in your report and to understand what you are submitting.

And that's why choosing the right CVE is the most important step!

